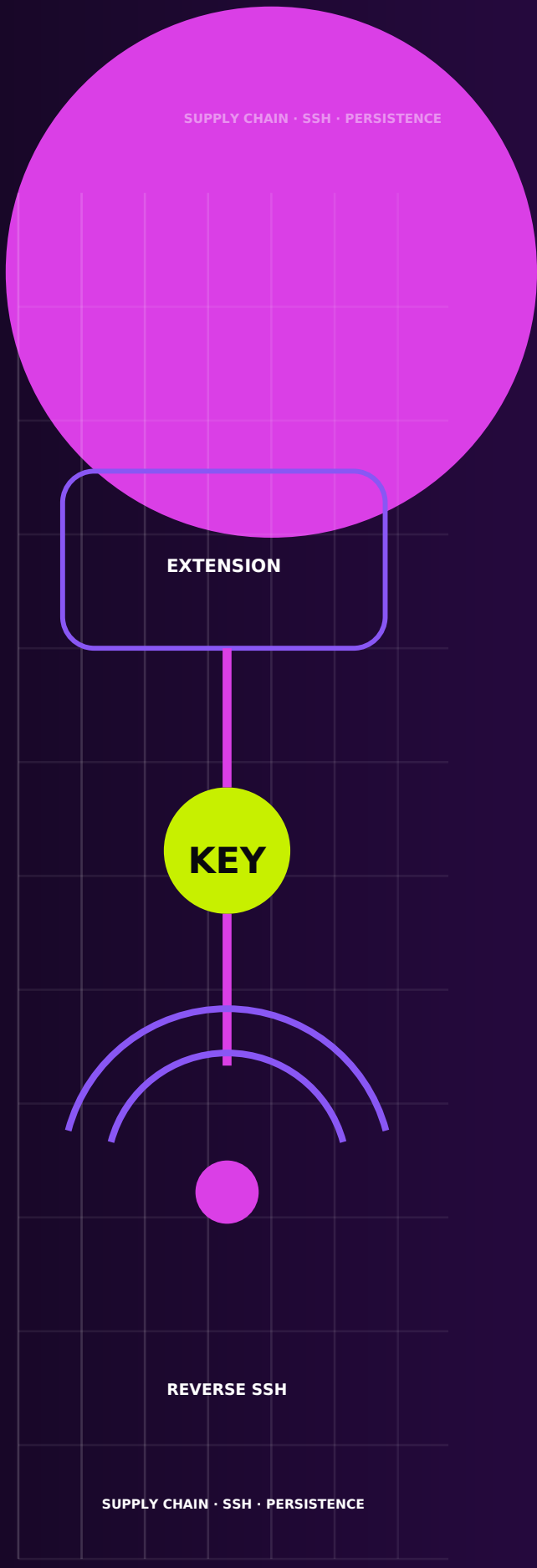
DETECTION THREAT LANDSCAPE

TROJANIZED CLAUDE CODE EXTENSION PERSISTENT SSH BACKDOOR

Multi-signal hunt for source-published persistence artifacts, infrastructure and reverse SSH behavior



HUNTING QUERY

CONFIDENCE: HIGH

REPORT TYPE
campaign

STATUS
Untested implementation sketch

PRIMARY PLATFORM
Microsoft Defender XDR

OPERATIONAL VALUE
9 / 10

01

Executive Assessment

Decision-grade summary with explicit evidence boundaries.

ASSESSMENT

DECISION

Publish a time-sensitive, multi-signal exposure hunt. Treat an exact hash or published infrastructure match as high-priority evidence; treat filenames and reverse-SSH grammar as investigative leads until extension provenance and adjacent persistence or authentication evidence are established.

SOURCE-CONFIRMED

- Microsoft reconstructed a five-stage loader sequence but explicitly stated that code order does not...
- Cursor reported that errors and missing administrative privileges blocked SSH access on most mac...
- Microsoft and Cursor published file, network, SSH-key and command-line indicators. [C003]

ANALYST ASSESSMENT

- Exact hashes and the published IP have high campaign specificity; filenames and SSH command...
- Independent file, process and network signals support a stronger exposure assessment than any...

DETECTION ASSUMPTIONS

- Defender for Endpoint retains file, process and network telemetry across the exposure and...
- Full command lines and hashes are populated sufficiently to distinguish authorized remote-development...

KEY FINDINGS

FINDING 1

Cursor Marketplace served malicious anthropic.claude-code versions 2.1.312 and 2.1.313 for a limited window on 29 October 2026; the official npm and Visual Studio Marketplace distributions were not affected. [C001]

FINDING 2

The injected loader attempted SSH authorized-key modification, local SSH enablement, reverse forwarding and cross-platform persistence. [C002]

FINDING 3

The source publishes exact hashes, paths, an infrastructure IP and reverse-SSH grammar suitable for independent evidence-layer hunting. [C003]

EVIDENCE BOUNDARY

The public evidence does not establish which exposed hosts accepted attacker authentication or whether commands were executed through a tunnel. A matching generic filename does not establish that the affected Cursor Marketplace extension created it.

02

Threat Mechanics

Technical mechanism, observable transitions and supported scope.

ATTACK FLOW

TECHNICAL BACKGROUND

The extension contained injected JavaScript that executed before normal initialization. It collected host context, attempted to append a public key marked svc-telemetry to SSH authorization files, enabled SSH where possible, wrote a separate tunnel identity and launched outbound reverse SSH forwarding. Platform-specific startup objects retried the tunnel after failure. [C002][C003]

1

SUPPLY-CHAIN EXPOSURE

The malicious extension version is installed or automatically updated from Cursor Marketplace. Observable: Extension inventory, package hash and marketplace provenance.

2

ACCESS PREPARATION

The loader attempts to append an attacker-controlled public key and enable SSH. Observable: authorized_keys modification, service changes and installer process lineage.

3

REVERSE FORWARDING

ssh or autossh requests remote forwarding to victim loopback port 22. Observable: Process command line and outbound connection to the published IP.

4

PERSISTENCE

LaunchAgent, cron, scheduled-task or Startup-folder artifacts relaunch the tunnel. Observable: Exact source-published paths, task objects and repeated SSH process creation.

5

HOST REPORTING

A delayed callback attempts to transmit collected host details. Observable: HTTP POST to the published beacon endpoint and adjacent extension execution.

03

Telemetry & Evidence Model

Minimum data contract and known visibility gaps.

DATA CONTRACT

PRIMARY PLATFORM

Microsoft Defender XDR. Union exact file artifacts and published infrastructure with constrained reverse-SSH command grammar, preserving signal strength and raw context.

FIELD / TABLE	STATUS	PURPOSE
DeviceFileEvents	**Required**	Exact hashes, filenames, paths and creating-process context.
DeviceNetworkEvents	**Required**	Connections to the published IP and beacon infrastructure.
DeviceProcessEvents	**Required**	ssh/autossh reverse-forwarding grammar and process lineage.
SHA256	**Required**	High-specificity artifact identity when populated.
ProcessCommandLine	**Required**	Reverse forwarding and host-key-check bypass context.
Extension inventory	**Enrichment**	Confirm affected version and Cursor Marketplace provenance.
SSH authentication logs	**Enrichment**	Determine whether the planted key was accepted.

KNOWN VISIBILITY GAPS

Deleted artifacts before sensor capture Unpopulated SHA256 Missing extension inventory SSH activity outside endpoint retention

04

Primary Detection Logic

Native query, explicit condition evidence and match meaning.

KQL

```
// Rule: [T1098.004][T1572] Malicious Claude Code Extension Backdoor Evidence
// MITRE ATT&CK: T1098.004 (SSH Authorized Keys), T1572 (Protocol Tunneling)
// Classification: Hunting query
// Status: Untested implementation sketch
// Primary platform: Microsoft Defender XDR Advanced Hunting
// Required telemetry: DeviceFileEvents, DeviceNetworkEvents, DeviceProcessEvents
// Logic: union exact published artifacts and infrastructure with a constrained
// reverse-SSH command pattern to expose independent evidence layers.
// A match proves: the corresponding endpoint telemetry matched one published
// artifact/infrastructure value or the defined reverse-forwarding grammar.
// A match does not prove successful tunnel establishment, attacker login,
// credential access, downstream execution, exfiltration, or attribution.
// Expected false positives: security research copies; generic filenames;
// authorized SSH forwarding. Validate path, provenance and adjacent evidence.
// Coverage limits: missing hashes, deleted files, encrypted traffic without
// endpoint process context, unsupported platforms and expired retention.
// Evidence claims: C001, C002, C003, C005, C006, C007
let Lookback = 30d;
let PublishedIP = "134.209.82.225";
union isfuzzy=true
(
    DeviceFileEvents
    | where Timestamp > ago(Lookback)
    | where SHA256 in~ (
        "ecb58cb29078d9646ad1dcdbe51526f2d9cfea06be5fb2ab183e8ecc3ab6bf15",
        "7e0a52885fadee05544a9e99eb18c792bec05900a5e1a66d68f8383decb0e278"
      )
      or FileName in~ (
        ".smt", ".smtk", "smt.cmd", "smtk",
        "sysmon.cmd", "com.apple.sysmond.plist"
      )
      or FileName matches regex @"(?i)^\.stk_[0-9a-f]{10}$"
    | extend SignalType = "FileArtifact",
             SignalStrength = iff(isnotempty(SHA256), "High", "Medium"),
             Evidence = strcat(FolderPath, " | SHA256=", SHA256),
             ActorProcess = InitiatingProcessFileName,
             ActorCommandLine = InitiatingProcessCommandLine,
             ActorAccount = InitiatingProcessAccountName,
             RemoteEvidence = ""
    | project Timestamp, DeviceId, DeviceName, SignalType, SignalStrength,
              Evidence, ActorProcess, ActorCommandLine, ActorAccount,
              RemoteEvidence, ReportId
),
(
    DeviceNetworkEvents
    | where Timestamp > ago(Lookback)
    | where RemoteIP == PublishedIP or RemoteUrl has PublishedIP
    | extend SignalType = "PublishedInfrastructure",
             SignalStrength = "High",
             Evidence = strcat("RemoteIP=", RemoteIP, ":", RemotePort),
             ActorProcess = InitiatingProcessFileName,
// ... complete 77-line query in hunting.kql
```

WHAT A MATCH PROVES

The corresponding Defender event matched one published artifact, infrastructure value or the defined reverse-forwarding grammar.

WHAT IT DOES NOT PROVE

Successful tunnel establishment, attacker authentication, command execution, credential theft, exfiltration or campaign attribution.

MATURITY

Hunting query - Untested implementation sketch. Union exact file artifacts and published infrastructure with constrained reverse-SSH command grammar, preserving signal strength and raw context.

05

Triage & Hunting Playbook

Evidence-preserving workflow from match to disposition.

WORKFLOW

01

Confirm Cursor installation, extension version 2.1.312/2.1.313 and Cursor Marketplace provenance; preserve the extension package before removal.

02

Collect matching files, SSH authorization files, startup objects, hashes, timestamps and creator-process lineage.

03

Review ssh/autossh processes, reverse-forwarding arguments, outbound connections and retry cadence around the first artifact event.

04

Inspect SSH server state and authentication logs for acceptance of the unauthorized key and post-authentication command execution.

05

Isolate hosts with loader execution or backdoor installation; remove exact malicious entries and rotate credentials or sessions from a known-clean device.

06

Close only when artifact ownership and provenance establish a benign collision with no adjacent suspicious behavior.

DISPOSITION RULE

Escalate only when the evidence establishes the behavior described by the query. Successful tunnel establishment, attacker authentication, command execution, credential theft, exfiltration or campaign attribution.

06

False Positives & Validation

Overlap model, controlled checks and promotion gate.

QUALITY GATE

GENERIC .SMT, .SMTK OR SYSMON.CMD NAMES

Require exact path, extension provenance, creator process or a second evidence layer.

AUTHORIZED SSH REVERSE FORWARDING

Validate owner, destination, identity path, change record and expected host-key policy.

SECURITY RESEARCH OR INCIDENT-RESPONSE COPIES

Confirm approved case timeline and prevent copied samples from being treated as execution evidence.

VALIDATION SEQUENCE

- Create benign files matching the published names and verify path, hash and creator fields across supported operating systems.
- Run an authorized SSH reverse-forwarding control and verify command-line and network representation without contacting malicious infrastructure.
- Measure filename and command-pattern prevalence across retention.
- Test exact-hash, published-IP and multi-signal branches independently.
- Confirm that approved remote-development workflows can be distinguished through destination, identity and ownership context.

SUCCESS

Each controlled evidence layer produces a complete row with correct device, path or command, actor context and signal strength; negative controls remain explainable.

REJECTION

Reject alert promotion when generic filenames or authorized SSH workflows cannot be separated, or when required fields are systematically absent.

PROMOTION GATE

At least one high-specificity branch or two independent medium-strength branches must be reproducible, with benign prevalence and ownership controls documented.

07

Analyst Assessment & References

Coverage statement, open questions and source record.

FINAL

CONCLUSION

This package is a high-confidence exposure hunt for a narrowly bounded supply-chain incident. Exact artifacts and infrastructure provide immediate value, while generic filenames and reverse-SSH behavior remain supporting evidence. Promotion to an alert requires local prevalence, extension provenance and controlled positive/negative validation.

MITRE ATT&CK

T1098.004 / T1572

PRIMARY AND AUTHORITATIVE REFERENCES

S001 Microsoft Security Research - Inside a malicious Claude Code-branded extension and its persistent SSH backdoor (2026-10-30)

hxxps://www[.]microsoft[.]com/en-us/security/blog/2026/10/30/inside-malicious-claude-code-branded-cursor-extension-persistent-ssh-backdoor/

S002 Cursor - Security notice - malicious version of Anthropic.claude-code identified in the Cursor VS Code Extension Marketplace (2026-10-29)

hxxps://prod[.]cursor[.]com/blog/claude-code-extension-security-notice

S003 Microsoft Learn - DeviceFileEvents table in the advanced hunting schema (undated)

hxxps://learn[.]microsoft[.]com/en-us/defender-xdr/advanced-hunting-devicefileevents-table

S004 Microsoft Learn - DeviceNetworkEvents table in the advanced hunting schema (undated)

hxxps://learn[.]microsoft[.]com/en-us/defender-xdr/advanced-hunting-devicenetworkevents-table

S005 Microsoft Learn - DeviceProcessEvents table in the advanced hunting schema (undated)

hxxps://learn[.]microsoft[.]com/en-us/defender-xdr/advanced-hunting-deviceprocessevents-table

S006 MITRE ATT&CK - Account Manipulation: SSH Authorized Keys (T1098.004) (2026-05-12)

hxxps://attack[.]mitre[.]org/techniques/T1098/004/

OPEN QUESTIONS

The public evidence does not establish which exposed hosts accepted attacker authentication or whether commands were executed through a tunnel. A matching generic filename does not establish that the affected Cursor Marketplace extension created it.

DOCUMENT CONTROL

Schema 2.0 | Layout 2.0 | Maturity hunting | Confidence High | No customer data | Evidence ledger required